

ICDFA Ethical Hacking Internship

INT308: Session Management and Web Security

Lab 4: Session Hijacking Test on OWASP Juice Shop

Written by: Fatima Abubakar

Student ID: ICDFA/2026/FAT/1542

Introduction

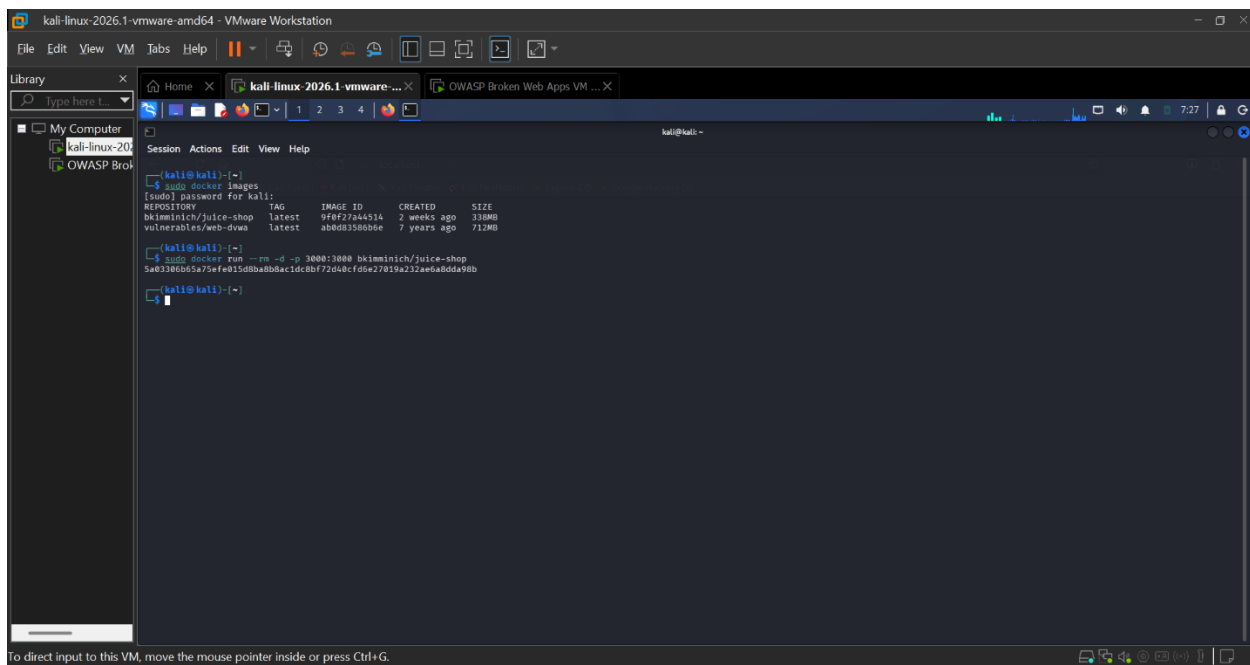
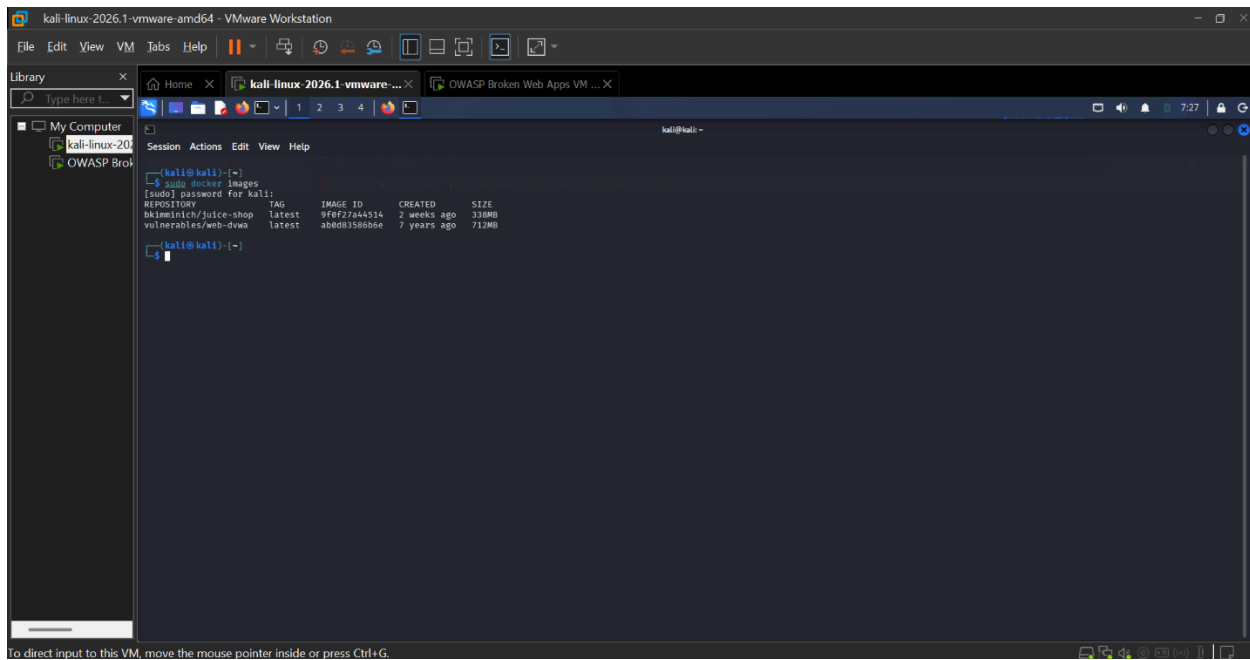
Session hijacking remains one of the most critical threats to web application security, compromising the confidentiality and integrity of authenticated user spaces. This attack occurs when an unauthorized individual intercepts, predicts, or steals a valid session identifier to impersonate a legitimate user without authenticating via credentials. Understanding session layer vulnerabilities is crucial for implementing robust access controls. This section evaluates the modern token-based architecture of OWASP Juice Shop to assess its structural resilience against session theft, predictability, and unauthorized replay scenarios.

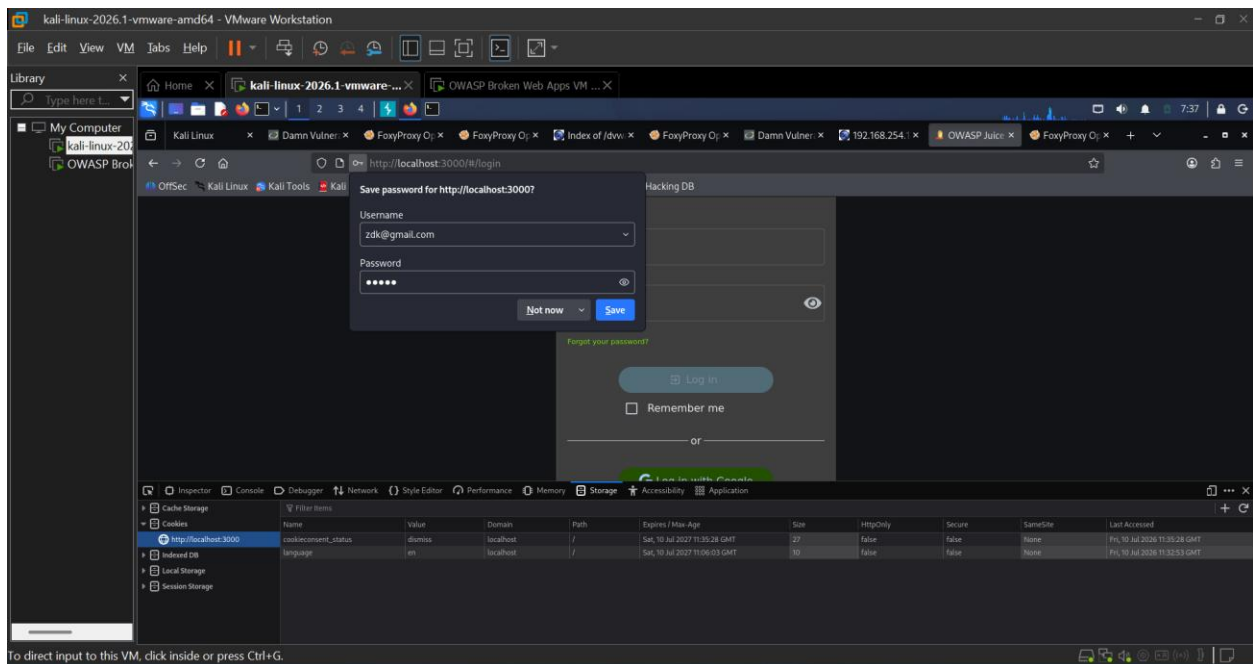
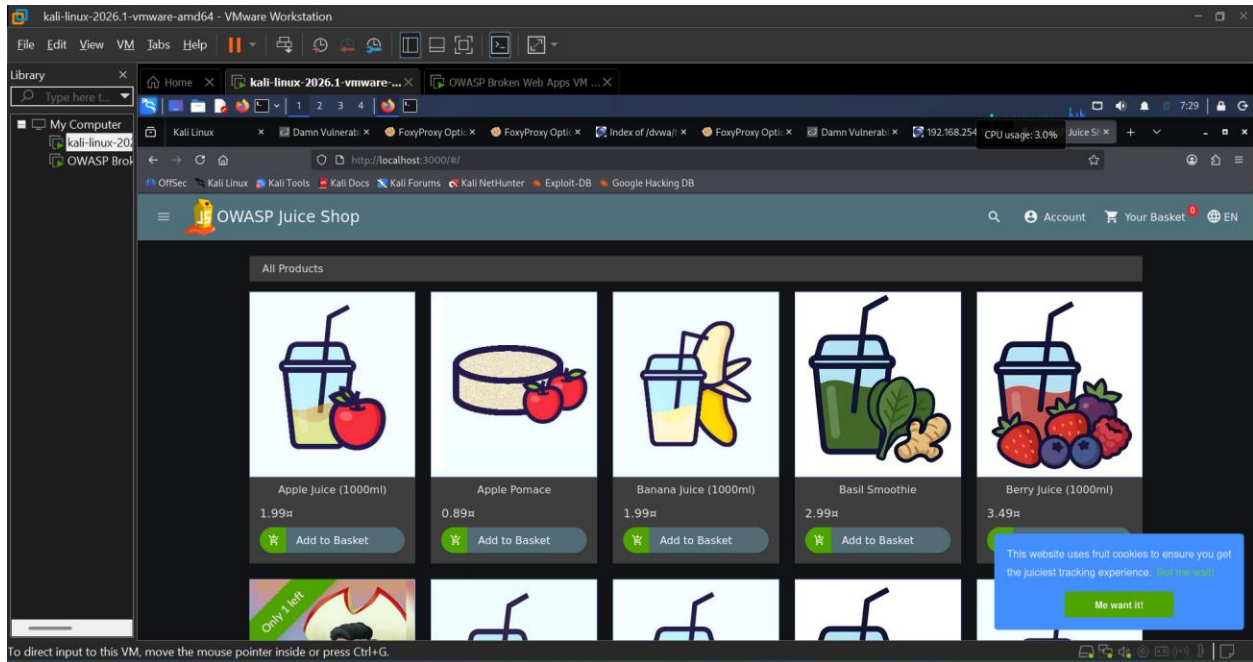
2. Methodology

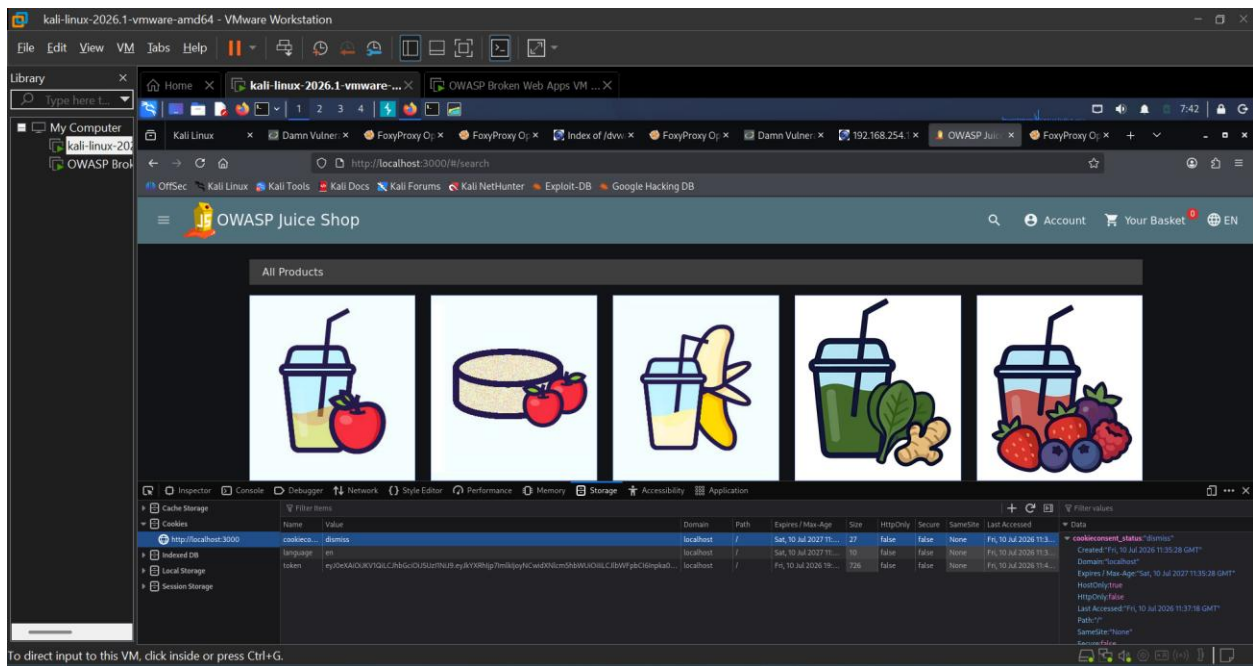
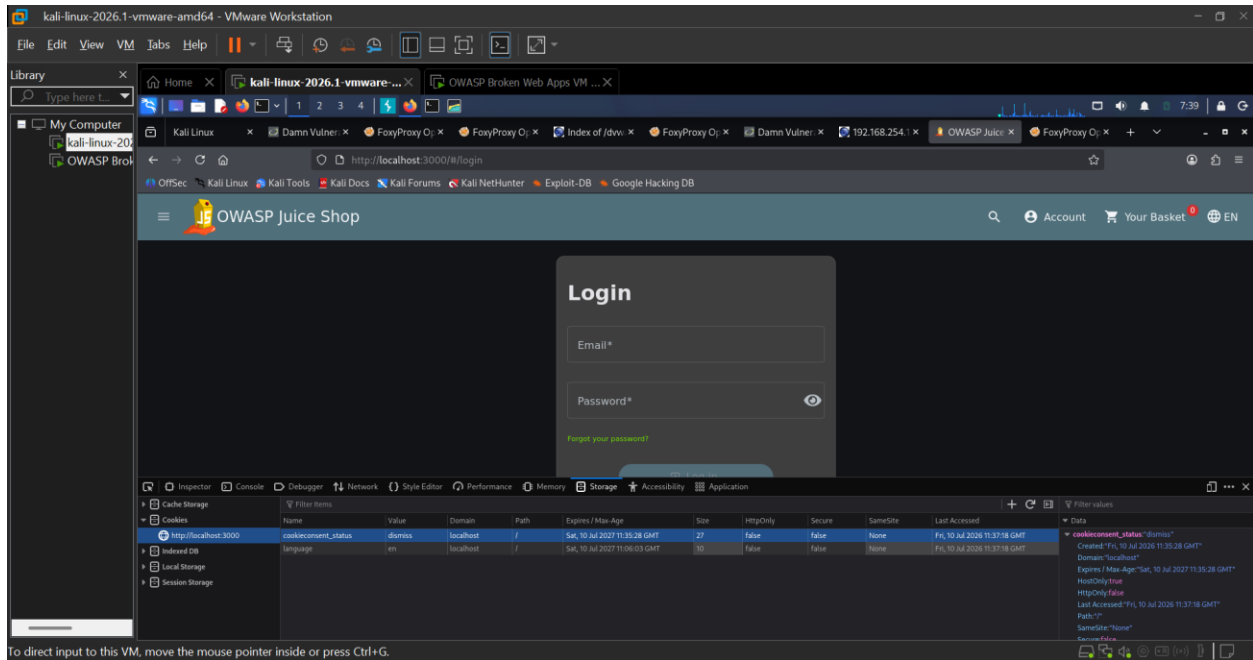
Testing was conducted within an isolated virtualization workspace using VMware Workstation 17 Pro. The target environment consists of an instance of the OWASP Juice Shop container deployed locally on port 3000 via Docker. The testing methodology followed an analytical security review checklist covering transport stability, token behavior, and session lifecycle validation.

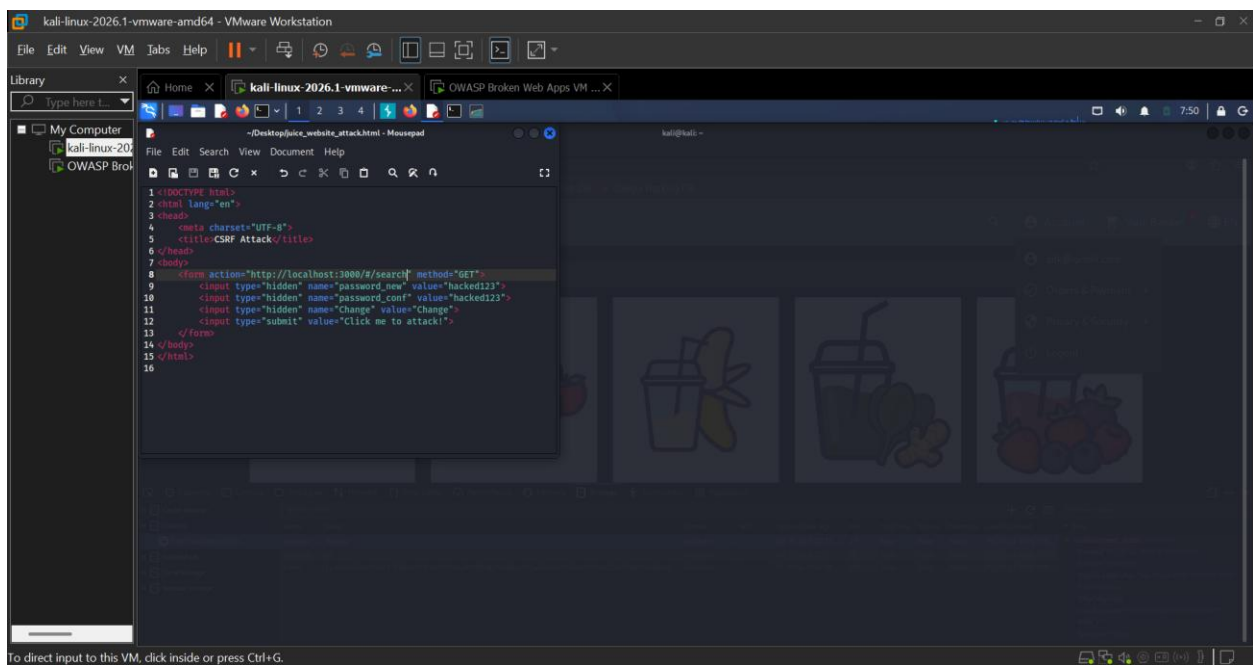
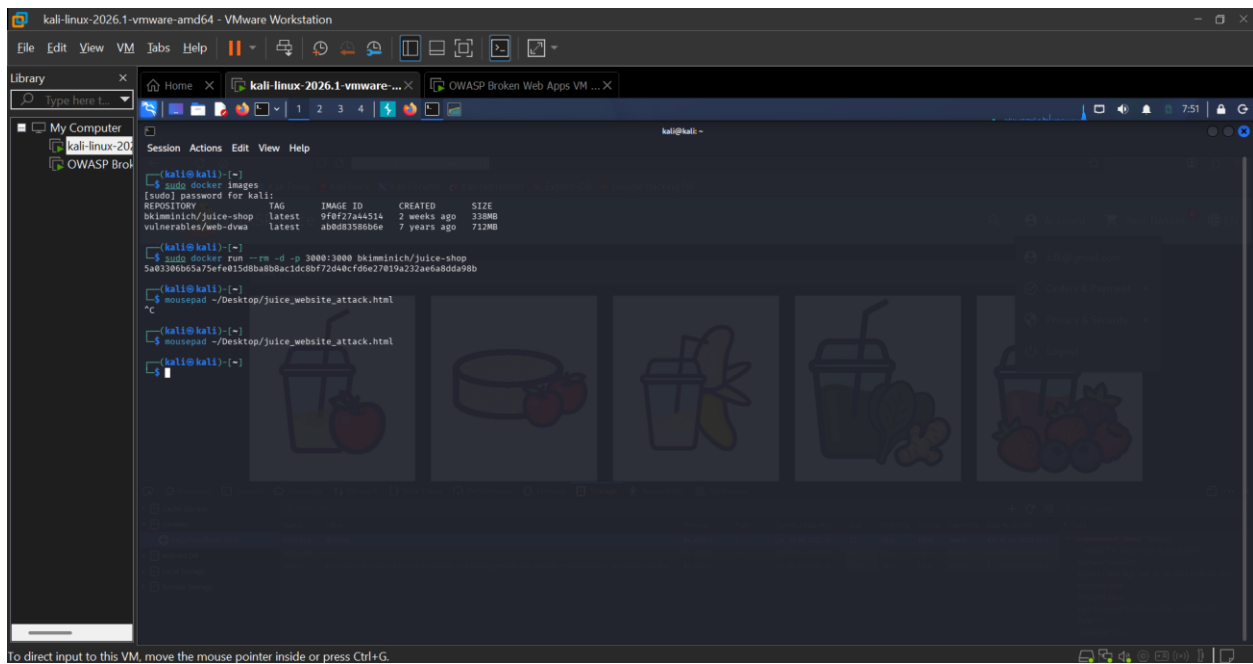
- **Environment Components:** Kali Linux VM (Attacker/Auditor Host machine) running alongside a background Node.js container instance.
- **Auditing Toolsets Utilized:** Mozilla Firefox Developer Tools (Storage Inspector Panel) for cookie parameter analysis; Wireshark Packet Analyzer for tracking cleartext loopback cross-sections.

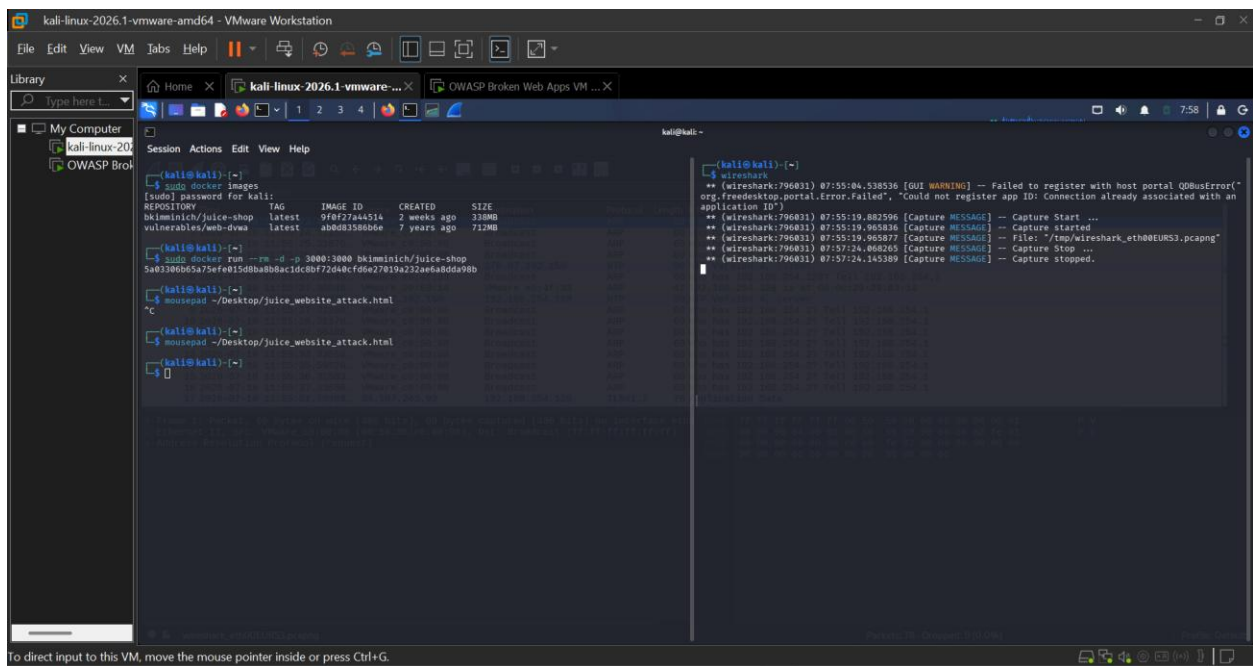
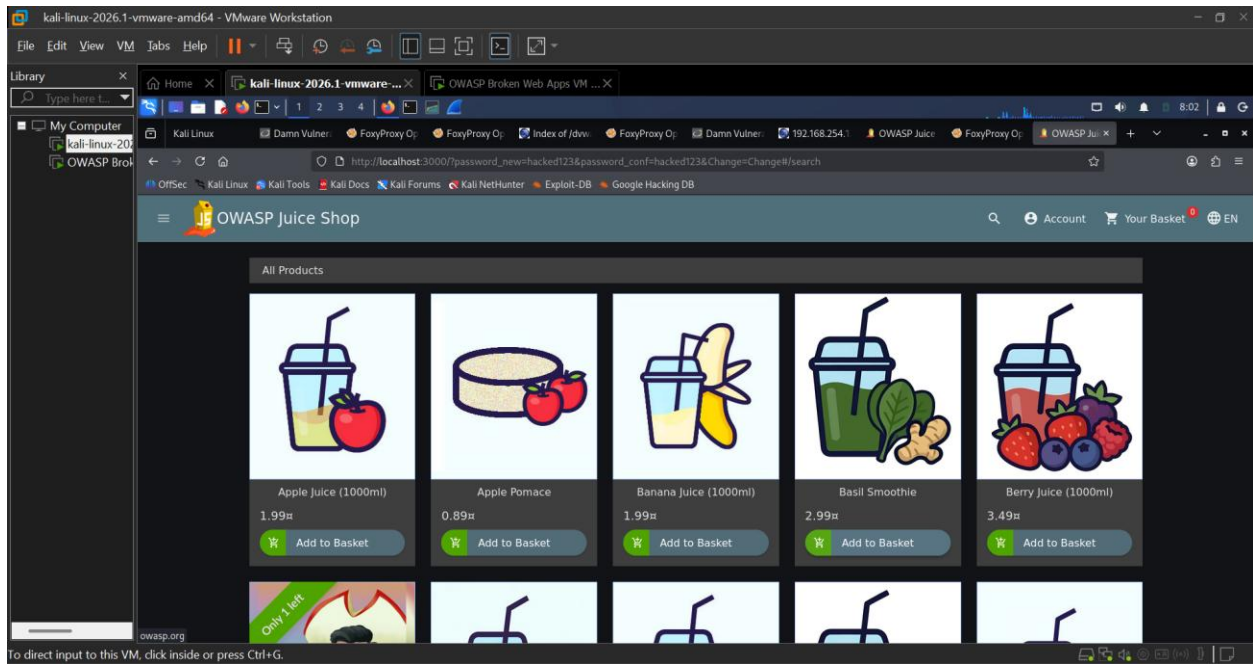
3. Findings & Vulnerability Analysis











kali-linux-2026.1-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

Home | kali-linux 2026.1-vmware-... | OWASP Broken Web Apps VM ...

My Computer

kali-linux-2026.1-vmware-... | OWASP Broken Web Apps VM ...

File Edit View Go Capture Analyze Statistics Telephony Tools Help

*eth0

Apply a display filter... <Ctrl>/

No.	Time	Source	Destination	Protocol	Length	Info
1	2026-07-10 11:55:22.48716	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
2	2026-07-10 11:55:24.31250	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
3	2026-07-10 11:55:25.31676	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
4	2026-07-10 11:55:26.51219	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
5	2026-07-10 11:55:27.21524	192.168.254.128	176.97.192.150	NTP	98	NTP Version 4, client
6	2026-07-10 11:55:27.30645	VMware_e6:4f:33	Broadcast	ARP	60	Who has 192.168.254.128? Tell 192.168.254.2
7	2026-07-10 11:55:27.30648	VMware_e6:4f:33	192.168.254.128	ARP	42	192.168.254.128 is at 00:0c:29:29:83:14
8	2026-07-10 11:55:27.30676	176.97.192.150	192.168.254.128	NTP	98	NTP Version 4, server
9	2026-07-10 11:55:27.31285	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
10	2026-07-10 11:55:28.32178	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
11	2026-07-10 11:55:32.56488	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
12	2026-07-10 11:55:33.33233	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
13	2026-07-10 11:55:34.33558	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
14	2026-07-10 11:55:35.59526	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
15	2026-07-10 11:55:36.32883	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
16	2026-07-10 11:55:37.33886	VMware_c0:00:00:00	Broadcast	ARP	60	Who has 192.168.254.2? Tell 192.168.254.1
17	2026-07-10 11:55:51.78369	34.187.243.93	192.168.254.128	TLSv1.2	78	Application Data

Frame 1: Packet, 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface eth0
Ethernet II, Src: VMware_c0:00:00:00, Dst: Broadcast (ff:ff:ff:ff:ff:ff)
Address Resolution Protocol (request)

wireshark_eth0EURL3.pcapng

Packets: 78 - Dropped: 0 (0.0%)

Profile: Default

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

kali-linux-2026.1-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

Home | kali-linux 2026.1-vmware-... | OWASP Broken Web Apps VM ...

My Computer

kali-linux-2026.1-vmware-... | OWASP Broken Web Apps VM ...

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

*eth0

CPU usage: 6.1%

Apply a display filter... <Ctrl>/

No.	Time	Source	Destination	Protocol	Length	Info
17	2026-07-10 11:55:51.78369	34.187.243.93	192.168.254.128	TLSv1.2	78	Application Data
18	2026-07-10 11:55:51.78369	192.168.254.128	34.187.243.93	TLSv1.2	82	Application Data
19	2026-07-10 11:55:51.78369	34.187.243.93	192.168.254.128	TCP	60	443 - 51272 [ACK] Seq=25 Ack=29 Win=64240 Len=0
20	2026-07-10 11:55:56.90139	VMware_e6:4f:33	VMware_e6:4f:33	ARP	42	Who has 192.168.254.2? Tell 192.168.254.128
21	2026-07-10 11:55:56.90187	VMware_e6:4f:33	VMware_e6:4f:33	ARP	60	192.168.254.2 is at 00:50:56:e0:4f:33
22	2026-07-10 11:56:05.24950	192.168.254.128	192.168.254.2	DNS	87	Standard query 0x07cc A safebrowsing.googleapis.com
23	2026-07-10 11:56:05.24967	192.168.254.128	192.168.254.2	DNS	87	Standard query 0x07cc A safebrowsing.googleapis.com
24	2026-07-10 11:56:05.46350	192.168.254.2	192.168.254.128	DNS	103	Standard query response 0x07cc A safebrowsing.googleapis.com A 142.250.140.95
25	2026-07-10 11:56:05.46350	192.168.254.2	192.168.254.128	DNS	115	Standard query response 0x07cc A safebrowsing.googleapis.com AAAA 2a00:1450:4009:c0b::5f
26	2026-07-10 11:56:05.48836	192.168.254.128	142.250.140.95	TCP	74	50446 - 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=2130072692 TSecr=0 W=256
27	2026-07-10 11:56:05.60693	142.250.140.95	192.168.254.128	TCP	60	443 - 50446 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
28	2026-07-10 11:56:05.60693	192.168.254.128	142.250.140.95	TCP	54	50446 - 443 [ACK] Seq=1 Ack=1 Win=64240 Len=0
29	2026-07-10 11:56:05.68302	192.168.254.128	142.250.140.95	TLSv1.3	2602	Client Hello (SN=safebrowsing.googleapis.com)
30	2026-07-10 11:56:05.68306	142.250.140.95	192.168.254.128	TCP	60	443 - 50446 [ACK] Seq=1 Ack=1461 Win=64240 Len=0
31	2026-07-10 11:56:05.68306	142.250.140.95	192.168.254.128	TCP	60	443 - 50446 [ACK] Seq=1 Ack=2549 Win=64240 Len=0
32	2026-07-10 11:56:05.68693	192.168.254.128	142.250.140.95	TLSv1.3	60	Change Cipher Spec
33	2026-07-10 11:56:05.68716	192.168.254.128	142.250.140.95	TLSv1.3	751	Application Data

Frame 33: Packet, 751 bytes on wire (6008 bits), 751 bytes captured (6008 bits) on interface eth0
Ethernet II, Src: VMware_e6:4f:33, Dst: VMware_e6:4f:33 (00:50:56:e0:4f:33)
Internet Protocol Version 4, Src: 192.168.254.128, Dst: 142.250.140.95
Transmission Control Protocol, Src Port: 50446, Dst Port: 443, Seq: 2550, Ack: 1, Len: 697
Transport Layer Security

wireshark_eth0EURL3.pcapng

Packets: 78 - Dropped: 0 (0.0%)

Profile: Default

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

kali-linux-2026.1-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

Home kali-linux-2026.1-vmware-... OWASP Broken Web Apps VM ...

Type here L...

My Computer

kali-linux-2026.1-vmware-... OWASP Broken Web Apps VM ...

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

*eth0

Apply a display filter ... <Ctrl+F>

No.	Time	Source	Destination	Protocol	Length	Info
33	2026-07-10 11:56:05.68716..	192.168.254.128	142.250.140.95	TLSv1.3	751	Application Data
34	2026-07-10 11:56:05.68721..	142.250.140.95	192.168.254.128	TCP	60	443 - 50446 [ACK] Seq=1 Ack=2555 Win=64240 Len=0
35	2026-07-10 11:56:05.68766..	142.250.140.95	192.168.254.128	TCP	60	443 - 50446 [ACK] Seq=1 Ack=3252 Win=64240 Len=0
36	2026-07-10 11:56:06.69659..	142.250.140.95	192.168.254.128	TLSv1.3	1454	Server Hello, Change Cipher Spec, Application Data
37	2026-07-10 11:56:06.69671..	192.168.254.128	142.250.140.95	TCP	54	50446 - 443 [ACK] Seq=3252 Ack=1401 Win=65535 Len=0
38	2026-07-10 11:56:06.70647..	192.168.254.128	142.250.140.95	TLSv1.3	154	Application Data, Application Data
39	2026-07-10 11:56:06.70699..	142.250.140.95	192.168.254.128	TCP	60	443 - 50446 [ACK] Seq=1401 Ack=3352 Win=64240 Len=0
40	2026-07-10 11:56:07.55413..	142.250.140.95	192.168.254.128	TLSv1.3	655	Application Data, Application Data, Application Data
41	2026-07-10 11:56:07.58824..	192.168.254.128	142.250.140.95	TLSv1.3	85	Application Data
42	2026-07-10 11:56:07.58872..	142.250.140.95	192.168.254.128	TCP	60	443 - 50446 [ACK] Seq=2002 Ack=3383 Win=64240 Len=0
43	2026-07-10 11:56:07.59565..	142.250.140.95	192.168.254.128	TLSv1.3	288	Application Data
44	2026-07-10 11:56:07.63713..	192.168.254.128	142.250.140.95	TCP	54	50446 - 443 [ACK] Seq=3383 Ack=2236 Win=65535 Len=0
45	2026-07-10 11:56:07.66995..	142.250.140.95	192.168.254.128	TLSv1.3	1454	Application Data
46	2026-07-10 11:56:07.67802..	192.168.254.128	142.250.140.95	TCP	54	50446 - 443 [ACK] Seq=3383 Ack=3636 Win=65535 Len=0
47	2026-07-10 11:56:07.67916..	142.250.140.95	192.168.254.128	TLSv1.3	651	Application Data, Application Data, Application Data
48	2026-07-10 11:56:07.67922..	192.168.254.128	142.250.140.95	TCP	54	50446 - 443 [ACK] Seq=3383 Ack=4233 Win=65535 Len=0
49	2026-07-10 11:56:07.67974..	192.168.254.128	142.250.140.95	TLSv1.3	93	Application Data

Frame 49: Packet, 93 bytes on wire (744 bits), 93 bytes captured (744 bits) on interface eth0

Ethernet II, Src: VMware_29:29:83:14, Dst: VMware_e6:4f:33 (00:50:56:e6:4f:33)

Internet Protocol Version 4, Src: 192.168.254.128, Dst: 142.250.140.95

Transmission Control Protocol, Src Port: 50446, Dst Port: 443, Seq: 3383, Ack: 4233, Len: 39

Transport Layer Security

wireshark_eth0EUS3.pcapng

Packets: 78 - Dropped: 0 (0.0%)

Profile: Default

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

kali-linux-2026.1-vmware-amd64 - VMware Workstation

File Edit View VM Tabs Help

Library

Home kali-linux-2026.1-vmware-... OWASP Broken Web Apps VM ...

Type here L...

My Computer

kali-linux-2026.1-vmware-... OWASP Broken Web Apps VM ...

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

*eth0

CPU usage: 2.0%

Apply a display filter ... <Ctrl+F>

No.	Time	Source	Destination	Protocol	Length	Info
49	2026-07-10 11:56:07.67974..	192.168.254.128	142.250.140.95	TLSv1.3	93	Application Data
50	2026-07-10 11:56:07.68007..	142.250.140.95	192.168.254.128	TCP	60	443 - 50446 [ACK] Seq=4233 Ack=3422 Win=64240 Len=0
51	2026-07-10 11:56:07.68022..	192.168.254.128	142.250.140.95	TLSv1.3	78	Application Data
52	2026-07-10 11:56:07.68036..	192.168.254.128	142.250.140.95	TCP	54	50446 - 443 [FIN, ACK] Seq=3446 Ack=4233 Win=65535 Len=0
53	2026-07-10 11:56:07.68048..	142.250.140.95	192.168.254.128	TCP	60	443 - 50446 [ACK] Seq=4233 Ack=3446 Win=64240 Len=0
54	2026-07-10 11:56:07.68069..	142.250.140.95	192.168.254.128	TCP	60	443 - 50446 [ACK] Seq=4233 Ack=3447 Win=64239 Len=0
55	2026-07-10 11:56:08.83112..	142.250.140.95	192.168.254.128	TCP	60	443 - 50446 [FIN, PSH, ACK] Seq=4233 Ack=3447 Win=64239 Len=0
56	2026-07-10 11:56:08.83118..	192.168.254.128	142.250.140.95	TCP	54	50446 - 443 [ACK] Seq=3447 Ack=4234 Win=12064 Len=0
57	2026-07-10 11:56:13.73769..	192.168.254.128	192.168.254.254	DHCP	324	DHCP Request - Transaction ID 0x677a28c8
58	2026-07-10 11:56:13.73885..	192.168.254.128	192.168.254.254	DHCP	342	DHCP ACK - Transaction ID 0x677a28c8
59	2026-07-10 11:56:18.92113..	VMware_e6:af:40	VMware_29:83:14	ARP	42	Who has 192.168.254.254? Tell 192.168.254.128
60	2026-07-10 11:56:18.92146..	VMware_e6:af:40	VMware_29:83:14	ARP	60	192.168.254.254 is at 00:50:56:e6:af:40
61	2026-07-10 11:56:31.46695..	192.168.254.128	176.97.192.150	NTP	90	NTP Version 4, client
62	2026-07-10 11:56:31.56744..	176.97.192.150	192.168.254.128	NTP	90	NTP Version 4, server
63	2026-07-10 11:56:36.05969..	192.168.254.128	192.168.254.255	BROWSER	274	Local Master Announcement OWASPBWA, Workstation, Server, Print Queue Server, Xenix Server,
64	2026-07-10 11:56:36.05969..	192.168.254.128	192.168.254.255	BROWSER	251	Domain/Workgroup Announcement WORKGROUP, NT Workstation, Domain Enum
65	2026-07-10 11:56:53.02774..	VMware_01:00:00:00:00:00	broadcast	ARP	60	Who has 192.168.254.254? Tell 192.168.254.128

Frame 65: Packet, 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface eth0

Ethernet II, Src: VMware_5f:fc:80 (00:0c:29:5f:fc:80), Dst: Broadcast (ff:ff:ff:ff:ff:ff)

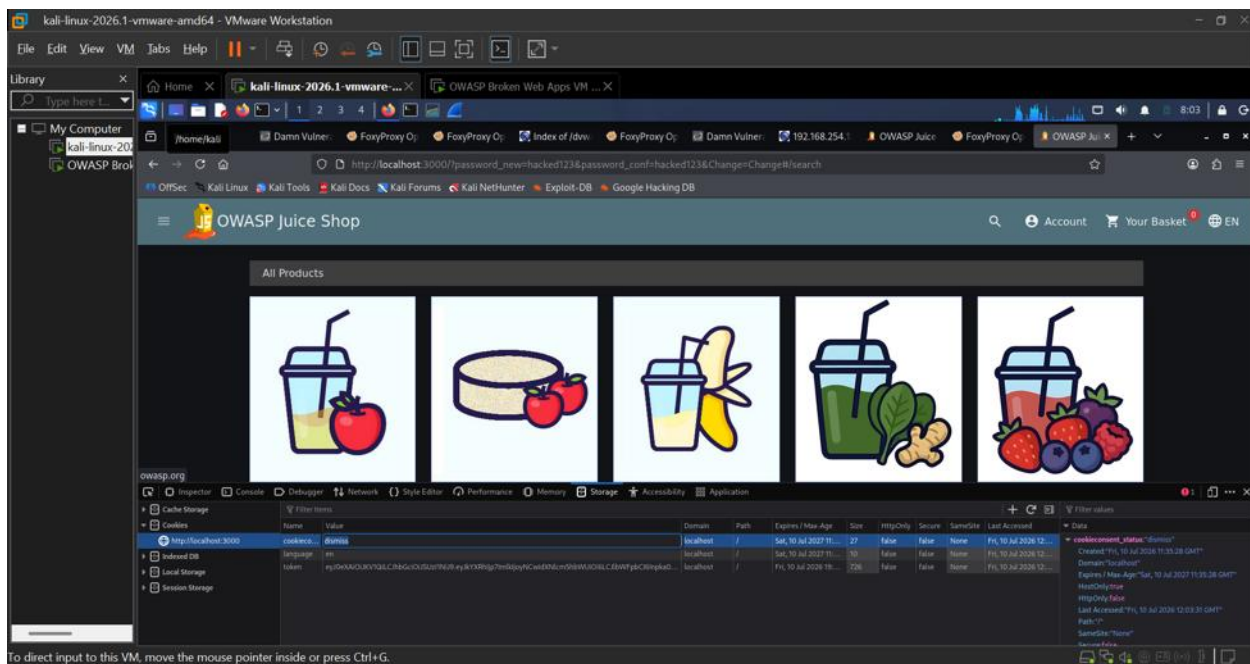
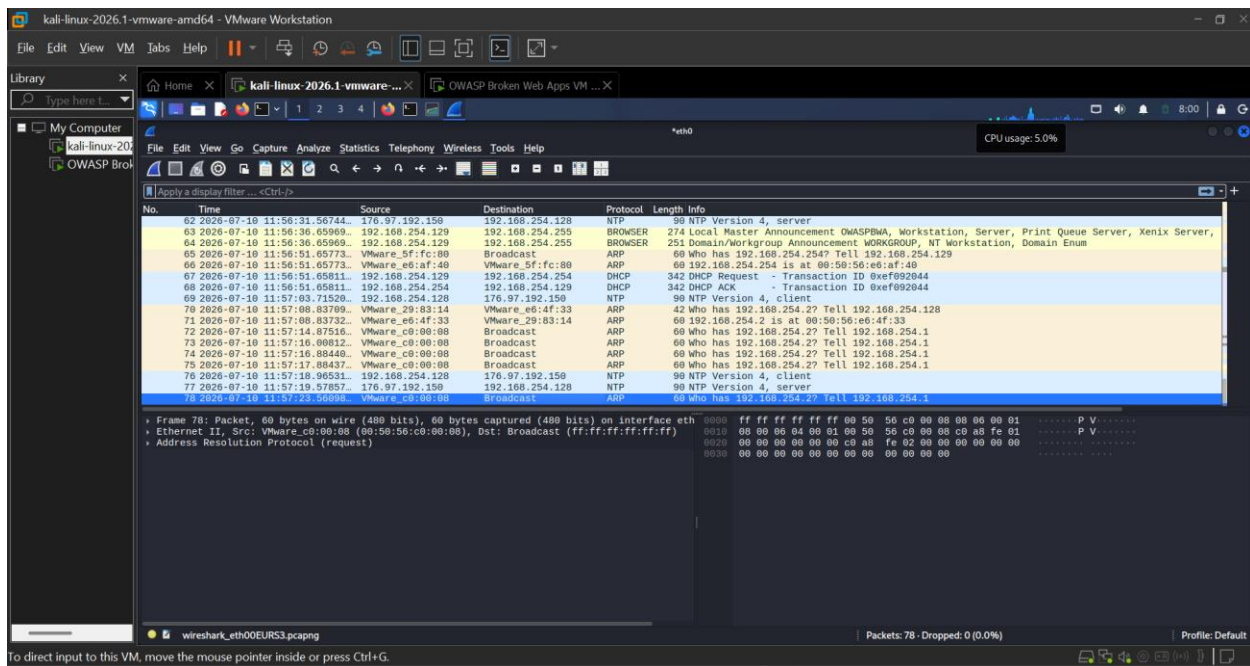
Address Resolution Protocol (request)

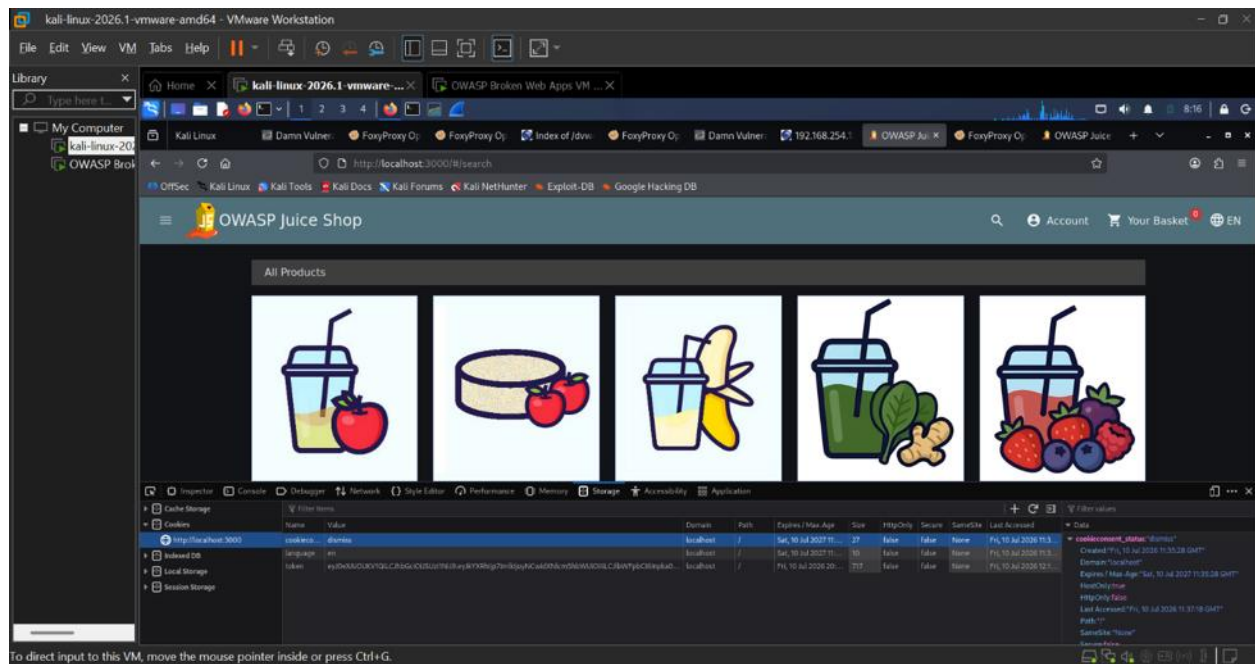
wireshark_eth0EUS3.pcapng

Packets: 78 - Dropped: 0 (0.0%)

Profile: Default

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.





Focus Area A: Session ID Inspection & Security Attributes

Upon inspecting the application's local database storage using the browser's Developer Tools, a primary cookie parameter named token was isolated. Unlike traditional database-backed random session strings, the row contains a multi-part JSON Web Token (JWT). Evaluation of its mandatory transport security flags revealed severe configuration defects:

- **HttpOnly = false:** This flag is disabled. Consequently, client-side browser scripts can read the token value dynamically over the DOM via document.cookie, exposing users to instant session compromise if any Cross-Site Scripting (XSS) vulnerability exists anywhere on the application domain.
- **Secure = false:** The cookie does not mandate transmission exclusively over encrypted channels, meaning it will happily pass across unencrypted networks.
- **SameSite = None:** The token is transmitted implicitly alongside cross-origin site navigations.

Focus Area B: Session ID Predictability & Structure Analysis

Because the environment relies on JWT structures, the session string cannot be easily brute-forced or mapped via standard sequential estimation. However, JWT strings are inherently stateless and merely Base64url-encoded rather than encrypted. Isolating the distinct structural blocks separated by dots (.) allowed text extraction:

- **Header Cryptographic Properties:** Decoding the initial block (eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9) reveals that older container sequences

utilize symmetric **HS256** algorithms, creating a single point of failure if key choices are weak. Subsequent upgraded testing captures register asymmetric **RS256** signatures.

- **Payload Component Visibility:** Decoding the payload sequence immediately prints cleartext attributes containing account parameters, such as the authentic user database id, user email, and access control role.

Focus Area C: Transport Security (Wireshark Capture)

Running passive trace captures via Wireshark during authentication workflows explicitly verified a total absence of Transport Layer Security (TLS/HTTPS). Because communications run over cleartext HTTP, raw GET and POST request headers pass seamlessly across the network interface. An adversary sniffing the transmission channel can instantly harvest the entire active Authorization: Bearer eyJ... or cookie metadata payload, establishing complete account access without tripping traditional authentication alerts.

Focus Area D: Session Expiration & Post-Logout Replay

Testing a session termination event exposed a critical flaw in backend validation. When a user executes an explicit "Logout" action, the front-end application safely purges the token from local storage footprint rows. However, because JSON Web Tokens are naturally stateless, the server does not actively maintain an immutable map of revoked blocks. By manually capturing the long eyJ... token prior to logging out, logging out, injecting a fresh cookie row named token via Developer Tools, and pasting the old value back in, refreshing the page grants immediate fully authenticated dashboard control. This proves the system is highly vulnerable to post-logout session replay attacks.

Focus Area E: Session Fixation Evaluation

When injecting a custom tracking cookie string (e.g., a custom identifier value) prior to accessing the authentication portal, the login function properly resets the context and issues a new cryptographically generated token layer. This behavior demonstrates that the login script isolates session parameters correctly during privilege escalation, making the application immune to basic pre-authentication session fixation vectors.

4. Countermeasures & Practical Recommendations

To mitigate these session management vulnerabilities on the OWASP Juice Shop platform, the following countermeasures should be implemented:

1. **Harden Cookie Transmission Parameters:** Enforce strict programmatic restrictions during application token delivery. The authentication token must be bound strictly within an HttpOnly cookie wrapper to neutralize XSS-based script access, alongside Secure=true flags to ensure transmission occurs only over encrypted TLS paths.

2. **Deploy Server-Side Token Revocation (Blocklisting):** Integrate an in-memory database layer (such as a high-performance Redis cache instance) on the application server. When a user clicks "Logout," the unique cryptographic signature of that specific token must be written to an active blocklist that the API gateway cross-references on every incoming request, instantly invalidating replayed tokens.
3. **Transition to Strict Cross-Origin Directives:** Update the cookie properties to SameSite=Lax or SameSite=Strict to stop browsers from automatically appending authentication keys to unauthorized cross-domain tracking sequences.

5. Conclusion

This hands-on CTF challenge highlights the critical importance of secure session lifecycle management. Stateless token paradigms like JWT offer exceptional engineering scalability, but they introduce unique, high-risk attack surfaces if left exposed without transport encryption or client-side script restrictions. Securing modern single-page applications requires a multi-layered approach: hardening browser storage boundaries, enforcing absolute HTTPS transmission via TLS, and maintaining runtime state revocation policies on the web backend.